

Cyber Security Governance, Risk, and Compliance (GRC) Strategies

Cyber Risk Management (CMP-X309-0)

University of Roehampton



Sawsan Mounes

Student ID: MOU23620003

April 2026

Table of Contents

<i>Incident 1. Data Breach – Compromise of Electronic Health Record (EHR) Database..</i>	<i>2</i>
<i>Incident 2. Phishing Attack – Compromise of Staff Credentials.....</i>	<i>4</i>
<i>Incident 3. Poor Encryption Practices – Legacy Authentication System Failure and Vulnerability to MITM Attacks</i>	<i>6</i>
<i>Incident 4. Misuse of Privileged Access – Insider Threat</i>	<i>8</i>
<i>Incident 5. DDoS Attack – Inadequate Response Plan</i>	<i>10</i>

Incident 1. Data Breach – Compromise of Electronic Health Record (EHR) Database

A misconfigured AWS S3 bucket containing historical EHR backups is discovered exposed to the internet after a recent acquisition. The files include identifiers, diagnoses, test results, and prescription history. 65,000 patient records are exfiltrated due to lack of encryption-at-rest, ineffective configuration auditing, and the files being publicly accessible for six months.

The data breach at MediConnect was primarily caused by a misconfigured AWS S3 bucket, which allowed anyone on the internet to publicly access electronic health record (EHR) backups. Publicly exposed backups contradict the purpose of having backups; therefore, MediConnect failed to implement proper access control and secure configuration practices. The absence of encryption represents a critical vulnerability, as it enables easy exploitation. The severity of the breach is high due to the data being stored in plaintext and fully exposed to unauthorised individuals.

Poor monitoring of organisational systems and inadequate staff training are clearly reflected in this incident. Ineffective configuration auditing allowed critical misconfigurations to persist, resulting in sensitive data being publicly accessible for six months without detection. This indicates a lack of oversight and failure to properly review system configurations, as well as insufficient staff awareness in identifying security risks. The fact that such exposure went unnoticed for an extended period highlights serious weaknesses in internal security practices, increasing the likelihood of unauthorised access and data exploitation.

This data breach has caused a significant impact on the business due to failure to follow the CIA triad. Confidentiality has been compromised, as 65,000 patient records were exposed to unauthorised individuals. This may lead to legal action, including regulatory fines, compensation claims, and financial losses, ultimately affecting the organisation's stability and reputation.

Integrity has also been undermined due to ineffective auditing, monitoring, and access control mechanisms, reducing trust in the accuracy and reliability of the data. Weak access controls increase the risk of unauthorised modification, further impacting trust in patient records and the system. This reduces patient confidence in MediConnect, making users less likely to rely on or continue using the service.

Availability may also be impacted, as systems may need to be taken offline during investigation and recovery, causing service disruption. As backup data was exposed, it may not be reliable for recovery, further delaying operations and affecting business continuity

In addition, this incident demonstrates clear non-compliance with the UK GDPR. MediConnect failed to follow data minimisation and storage limitation principles, as sensitive historical backups were retained without proper protection or clear necessity. The lack of encryption and access control also violates the requirement to implement appropriate technical and organisational measures to ensure the security of personal data. [8]

Under GDPR Article 33, MediConnect is required to report the breach to the Information Commissioner's Office (ICO) within 72 hours of becoming aware of it. Under Article 34, the organisation must notify affected individuals due to the high risk posed by the exposure of sensitive health data. Failure to comply may result in further regulatory penalties

From an ISO/IEC 27001 perspective, this incident highlights weaknesses in access control (A.9), cryptographic controls (A.10) , and operations security (A.12), particularly in monitoring and configuration management. These failures indicate poor implementation of security policies and risk management practices [6].

The breach may also expose MediConnect to contractual risks with NHS partners. Failure to meet Data Security and Protection Toolkit (DSPT) requirements could result in penalties, loss of trust, or contract termination.

To mitigate these risks, MediConnect should enforce strict access controls, disable public access by default, and implement encryption at rest. Continuous monitoring and automated

configuration auditing should be introduced, alongside regular security assessments, particularly after acquisitions. Staff training should also be improved to strengthen awareness of security risks.

Overall, this incident highlights both technical and organisational failures. Strengthening governance, security controls, and compliance should be prioritised to prevent similar breaches.

Incident 2. Phishing Attack – Compromise of Staff Credentials

A sophisticated spear-phishing campaign targeted MediConnect employees culminating in the compromise of the Finance Director's account and unauthorised access to internal systems. The attack began with credential harvesting and escalated to lateral movement within the network.

The phishing attack enabled unauthorised system access by exploiting weaknesses in MediConnect's email security and staff awareness. The attacker used a spear-phishing email to trick the Finance Director into providing login credentials. Once these credentials were obtained, the attacker was able to access internal systems. Due to weak authentication controls, this access was not prevented, allowing the attacker to move easily within the network and gain access to additional systems.

The main issue in this incident was the failure to detect and block the phishing email. The IT team did not implement effective email filtering systems, allowing the malicious email to reach the user. In addition, threat detection systems were ineffective, as unusual login activity was not identified in time. This demonstrates a lack of monitoring and detection capabilities within the organisation [1].

A key weakness was the absence of multi-factor authentication (MFA). There are many types of MFA available, such as text message codes, authentication apps, and biometric verification, making it relatively easy for organisations to implement. Therefore, the failure to use MFA highlights a significant gap in MediConnect's security controls. Without MFA, attackers were able to gain access using only stolen credentials [1].

Staff awareness also played a major role in this incident. Employees were unable to recognise the phishing email, which allowed the attack to succeed. Staff training is a simple and effective way to prevent phishing attacks, as it helps employees identify suspicious emails and avoid sharing sensitive information. Without proper training, employees become more vulnerable to social engineering attacks.

From a NIST Cybersecurity Framework perspective, this incident highlights weaknesses across several areas. Under Identify, MediConnect failed to recognise high-risk accounts, such as the Finance Director, as critical assets requiring stronger protection. Under Protect, MFA and adequate staff training were not implemented, increasing vulnerability to phishing attacks. Under Detect, the organisation failed to identify the phishing email and unusual login activity. Under Respond, there were no immediate actions taken to stop the attack or limit its spread. Under Recover, improvements are required to strengthen security controls and prevent similar incidents in the future [1].

To reduce this risk, MediConnect should implement mandatory MFA for all users, particularly high-level accounts. Strong email filtering systems should be introduced to block phishing emails before they reach employees. Regular staff training should be provided to improve awareness and help employees recognise phishing attempts. The organisation should also carry out simulated phishing tests to assess and improve staff behaviour. In addition, continuous monitoring should be implemented to detect unusual activity and respond quickly to threats.

Overall, this incident demonstrates how phishing attacks can lead to unauthorised system access when detection, authentication, and staff awareness controls are weak. Strengthening these areas and aligning with recognised cybersecurity practices is essential to prevent similar attacks in the future [1].

Incident 3. Poor Encryption Practices – Legacy Authentication System Failure and Vulnerability to MITM Attacks

Incident 3. Poor Encryption Practices – Legacy Authentication System Failure and Vulnerability to MITM Attacks

Several legacy modules within MediConnect's patient portal still use outdated SHA-1 hashing and TLS 1.0. During a routine penetration test, it is discovered that attackers

2

could intercept and decrypt login traffic through a man-in-the-middle attack, gaining unauthorised access to patient accounts.

The main issue in this incident is the use of weak and outdated encryption protocols, particularly SHA-1 and TLS 1.0. SHA-1 is no longer considered secure, as it is vulnerable to attacks and does not provide strong protection. It was recommended by NIST to be deprecated in 2011 and was fully disallowed for digital signatures by 2013 due to known vulnerabilities and the risk of brute-force attacks. This suggests that MediConnect failed to update its systems and transition to stronger hashing algorithms, despite having many years to do so [6].

In addition, TLS 1.0 is also considered insecure, as it is an outdated protocol with known vulnerabilities, including weak encryption methods and issues with cipher block chaining. It lacks support for modern security standards and is no longer compliant with current regulations. Earlier protocols such as SSL are also fully deprecated and should not be used. This shows that MediConnect failed to keep its security systems up to date and relied on legacy technologies. Poor configuration and lack of regular updates further increased the risk, reflecting weak security management [5].

In a healthcare environment, patients are expected to trust the system, as their lives and personal information are in the hands of healthcare providers. They expect their data to remain confidential and secure. However, due to MediConnect's weak security, the organisation has placed itself in a vulnerable position where attackers can gain unauthorised access and bypass

systems. This can lead to exposure of sensitive patient data and financial information, such as card payments.

Compromised accounts may result in misuse of patient data or disruption of healthcare services, which can impact patient care and reduce trust in the system. This also violates UK GDPR requirements, as organisations are required to protect personal data using appropriate security measures. Failure to do so may result in legal and regulatory consequences.

From an ISO/IEC 27001 perspective, this incident highlights failures in key security control areas. MediConnect failed to apply proper cryptographic controls, as outdated encryption methods such as SHA-1 and TLS 1.0 were still in use. ISO 27001 requires organisations to use strong encryption and secure key management to protect sensitive data [6].

Network security controls were not effectively applied, as secure communication channels were not maintained, allowing attackers to intercept data. The organisation also failed to maintain secure configurations and regularly update systems, increasing the risk of vulnerabilities.

From a NIST Cybersecurity Framework perspective, this shows weaknesses mainly under the Protect function, as secure encryption was not used to safeguard data in transit. It also highlights issues under Detect, as the organisation did not identify the vulnerability early, and Respond, as there were no immediate actions taken to fix the issue before it could be exploited [1].

To address this issue, MediConnect should replace outdated encryption protocols with secure alternatives such as TLS 1.2 or TLS 1.3 and completely disable TLS 1.0 and SSL. Stronger hashing algorithms, such as SHA-256, should be used instead of SHA-1. Proper certificate management should be implemented to ensure certificates are valid, trusted, and regularly updated.

Regular security testing and system updates should also be carried out to ensure encryption standards remain secure and up to date [6].

Incident 4. Misuse of Privileged Access – Insider Threat

Incident 4. Misuse of Privileged Access – Insider Threat

A database administrator with full root access to AWS RDS copies patient data to a personal device before leaving the company due to dissatisfaction and high workload. The organisation has no Privileged Access Management (PAM), no monitoring of admin activity, and incomplete joiners-movers-leavers processes.

The misuse in this incident occurred due to excessive access being given to employees. The administrator was given full root access without any restrictions, which allowed confidential data to be accessed and copied. This level of access meant the administrator could view and control all data within the system.

Furthermore, MediConnect failed to implement a Privileged Access Management (PAM) system to control and limit how much access an employee should have, including high-level roles such as administrators. In addition, the organisation failed to properly monitor admin activity, as there was no continuous monitoring or auditing in place to detect suspicious behaviour when the administrator misused their privileges [4].

The organisation also failed to update or remove access before the employee left, showing weaknesses in the joiners-movers-leavers process. This reflects poor security management and a failure to control high-risk user access. Insider threats are particularly dangerous because employees already have access to internal systems and are familiar with security processes, making their actions harder to detect.

This incident highlights serious insider threat risks, as employees with high-level access can misuse their privileges when proper controls are not in place. In this case, sensitive patient data was copied without authorisation, increasing the risk of data breaches and misuse of personal information.

In a healthcare environment, this is particularly serious, as patients trust organisations to keep their confidential data safe and secure. This also goes against the requirements of the UK GDPR, which requires organisations to protect personal data from unauthorised access.

From a COBIT perspective, this incident shows weaknesses in governance and control of information systems. COBIT emphasises the importance of managing access, monitoring user activity, and ensuring accountability. In this case, MediConnect failed to implement proper governance controls, as privileged access was not restricted or monitored [2].

There was also a lack of audit mechanisms to track user actions, which allowed the data to be copied without detection. This reflects weaknesses under Principle C (People), particularly Action C1, which focuses on promoting a strong cybersecurity culture and accountability [3].

In addition, Principle D (Incident planning, response and recovery), specifically Action D4, highlights the importance of reviewing incidents and learning from them. MediConnect did not have effective monitoring or review processes in place, meaning the misuse of access was not detected or addressed in time [3].

From a NIST Cybersecurity Framework perspective, this incident highlights clear failures under the Protect and Detect functions. Under Protect, there was no PAM or role-based access control (RBAC) in place, and employees were given excessive access to sensitive data.

Under Detect, the organisation failed to monitor admin behaviour or identify anomalies, allowing the administrator to copy sensitive patient data without being noticed. This shows that MediConnect did not have effective monitoring or detection systems in place, increasing the overall risk to the organisation [1].

To reduce this risk, MediConnect should implement a PAM system to control and monitor high-level access. PAM enforces the principle of least privilege, meaning employees only have access to what they need for their role. It can also provide temporary just-in-time access instead of permanent privileges and supports continuous monitoring of admin activity.

Secure credential management, such as password vaulting and automatic rotation, further reduces the risk of unauthorised access. Overall, PAM strengthens control, visibility, and accountability, helping to prevent insider threats [4].

Incident 5. DDoS Attack – Inadequate Response Plan

MediConnect's telemedicine platform becomes the target of a Distributed Denial-of-Service (DDoS) attack during peak consultation hours, causing widespread service outages and preventing patients from accessing appointments and prescription services.

The organisation's untested incident response plan fails to mobilise teams effectively, and there is no automated traffic filtering or service continuity strategy.

The incident involves a Distributed Denial-of-Service (DDoS) attack targeting MediConnect's telemedicine platform during peak consultation hours. This caused widespread service outages, preventing patients from accessing appointments and prescription services. The attack overwhelmed the system with high volumes of traffic, making the platform unavailable.

The situation was made worse by the organisation's untested incident response plan, which failed to mobilise teams effectively.

The main issue is the lack of preparedness and ineffective incident response planning.

MediConnect did not have a well-tested or coordinated response strategy, leading to delays in handling the attack. There was no automated traffic filtering to detect and block malicious traffic, monitoring systems were weak, and there were failures in escalation and communication between teams.

This reflects poor planning and lack of readiness to handle high-impact cyber incidents. This incident had a significant impact on service availability, as patients were unable to access essential healthcare services, potentially delaying consultations and treatment and reducing trust in the platform.

From a NIST Cybersecurity Framework perspective, this highlights failures across several functions. Under Identify, MediConnect failed to recognise DDoS attacks as a key risk to service availability. Under Protect, there were no safeguards such as traffic filtering or rate limiting.

Under Detect, the organisation failed to identify the attack early due to weak monitoring. Under Respond, the incident response plan was ineffective. Under Recover, there were no clear strategies to restore services quickly and maintain continuity [1].

From an ITIL service management perspective, this shows weaknesses in incident management and service continuity planning. ITIL emphasises structured processes for detecting, responding to, and recovering from incidents. MediConnect failed to properly manage the incident, with no clear escalation process or effective communication between teams.

To reduce this risk, MediConnect should implement stronger monitoring and detection systems to identify DDoS attacks early. Automated traffic filtering and rate limiting should be introduced. The organisation should regularly test and update its incident response plan, establish clear escalation and communication procedures, and implement a service continuity plan including backup systems and failover strategies.

Overall, improving monitoring, response coordination, and resilience is essential to maintain reliable healthcare services [1].

References

[1]

NIST, "Cybersecurity Framework," *National Institute of Standards and Technology*, 2025.

<https://www.nist.gov/cyberframework>

[2]

ISACA, "COBIT | Control Objectives for Information Technologies | ISACA," *ISACA*, 2019.

<https://www.isaca.org/resources/cobit>

[3]

D. for, "Mapping cyber governance code to ISACA COBIT-19," *GOV.UK*, Apr. 07, 2025.

<https://www.gov.uk/government/publications/cyber-governance-mapping/mapping-cyber-governance-code-to-isaca-cobit-19#principle-c-people>

(accessed Apr. 13, 2026).

[4]

T. H. News, "How PAM Mitigates Insider Threats: Preventing Data Breaches, Privilege Misuse, and More," *The Hacker News*, Mar. 26, 2025. <https://thehackernews.com/2025/03/how-pam-mitigates-insider-threats.html>

[5]

NCSC, "Using TLS to protect data," *www.ncsc.gov.uk*, Jul. 21, 2021.

<https://www.ncsc.gov.uk/guidance/using-tls-to-protect-data>

[6]

International Organization for Standardization, "ISO/IEC 27001 standard – information security management systems," *ISO*, 2022. <https://www.iso.org/standard/27001>

[7]

Week 7: ISO/IEC 27001 [PowerPoint presentation]. CMP-X309-0: Cyber Risk Management.

University of Roehampton.(lata)

[8]

GDPR, "General Data Protection Regulation (GDPR)," *GDPR*, 2018. <https://gdpr-info.eu/>